

DOMAIN 3

INFORMATION SYSTEMS ACQUISITION, DEVELOPMENT AND IMPLEMENTATION

1

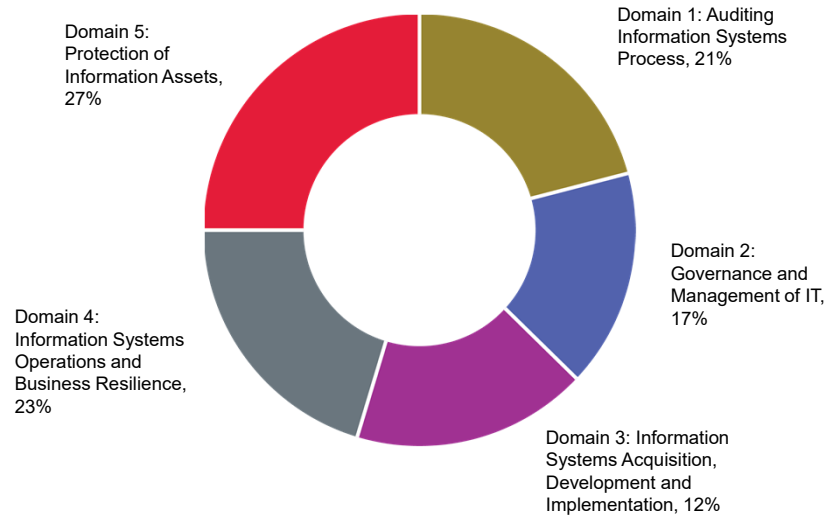
DOMAIN 3

This chapter on information systems acquisition, development and implementation provides an overview of key processes and methodologies used by organizations when creating and changing application systems and infrastructure components.



2

ON THE CISA EXAM



ISACA

3

DOMAIN 3 OBJECTIVES

Upon completion of this domain an IS auditor should be able to:

- Evaluate whether the business case for proposed changes to information systems meet business objectives.
- Evaluate the organization's project management policies and practices.
- Evaluate controls at all stages of the information systems development lifecycle.
- Evaluate the readiness of information systems for implementation and migration into production.
- Conduct post-implementation review of systems to determine whether project deliverables, controls, and requirements are met.
- Evaluate change, configuration, release, and patch management policies and practices.



4

DOMAIN 3 TOPICS

Information Systems Acquisition and Development

- Project Governance and Management
- Business Case and Feasibility Analysis
- System Development Methodologies
- Control Identification and Design

Information System Implementation

- Testing Methodologies
- Configuration and Release Management
- System Migration, Infrastructure Deployment, and Data Conversion
- Post-Implementation Review

5

ISACA

5



6

INTRODUCTION

For an IS auditor to provide assurance that an organization's objectives are being met by the management practices of its information systems, it is important that an IS auditor understand how an organization evaluates, develops, implements, maintains and disposes of its information systems and related components.

7



7

PROJECT GOVERNANCE AND MANAGEMENT

ISACA

8

PROJECT ROLES AND RESPONSIBILITIES

ISACA

9

KEY TERMS

Key Term	Definition
Project	A structured set of activities concerned with delivering a defined capability (that is necessary, but not sufficient, to achieve a required business outcome) to the enterprise based on an agreed-on schedule and budget.
Project Portfolio	The set of projects owned by a company. It usually includes the main guidelines relative to each project, including objectives, costs, time lines and other information specific to the project.
Program Evaluation and Review Technique (PERT)	A project management technique used in the planning and control of system projects.

ISACA

10

PROJECTS VS. PROGRAMS

Project

- Has specific objectives, deliverables, and start and end dates
- Always time-bound
- Usually broken into explicit phases

Programs

- Group of projects and time-based tasks closely linked through a common objective
- More complex
- Usually have a longer duration, higher budget and higher risk
- Have higher strategic importance

ISACA

11

PROJECT MANAGEMENT

The project management approach is dependent on the size of the organization and complexity of the business.

Prior to project involvement, the IS auditor must become familiar with the standard or structure used by the organization.

Project management processes include:

- Initiating
- Planning
- Executing
- Controlling
- Closing

ISACA

12

PROJECT CONTEXT

When analyzing the context of a project, the IS auditor must consider:

- Importance of the project in the organization
- Connection between the organization's strategy and the project
- Relationship between the project and other projects
- Connection between the project and the underlying business case

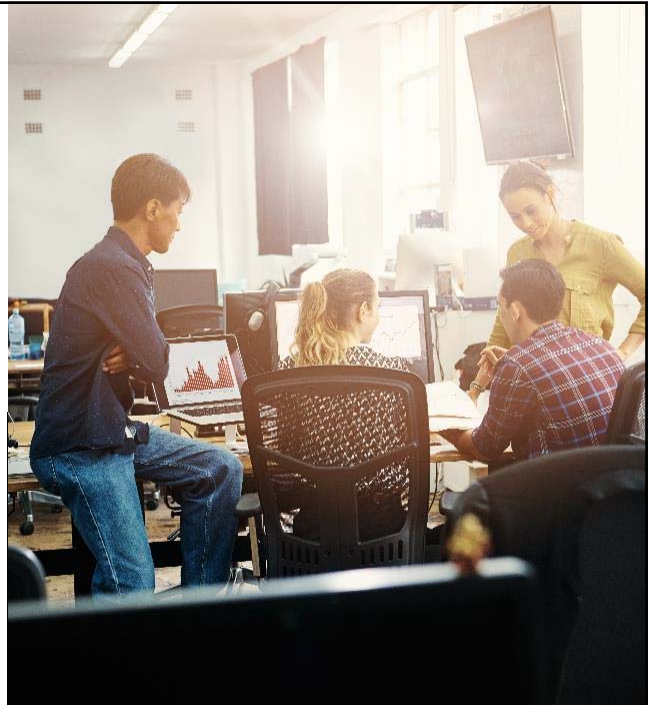
ISACA

13

PROJECT CONTEXT ENVIRONMENTAL FACTORS

Understanding the environment and context of the projects help to identify:

- Common objectives for the organization
- Risk
- Resource connections



14

PROJECT ORGANIZATION

Influence project organization

- The project manager has only a staff function without formal management authority.

Pure project organization

- The project manager has formal authority over those taking part in the project.

Matrix project organization

- Management authority is shared between the project manager and the department heads.

ISACA

15

ROLES AND RESPONSIBILITIES

The audit function should have an active part in application development projects, often as control experts.

The CISA should be familiar with general roles and responsibilities in project management, including:



ISACA

16

PROJECT COMMUNICATION

Communicate project initiation through:

- One-on-one meetings
- Kick-off meetings
- Project start workshops
- Combination of the above

Communication should be open, clearly presented and documented.



17

PROJECT CULTURE

A project culture is comprised of shared norms, beliefs, values and assumptions of the project team.

The project culture can be defined through a mission statement, project name and logo, project office or meeting place, communication protocols, project intranet, etc.

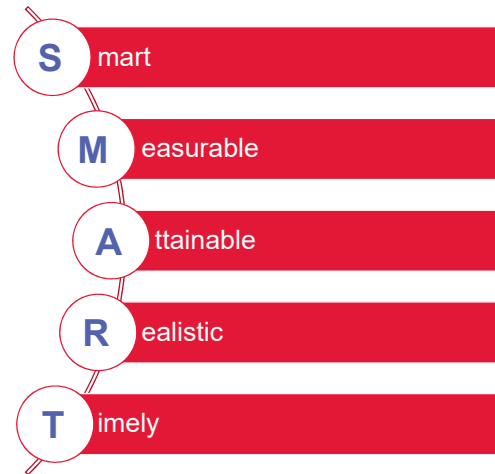


18

PROJECT OBJECTIVES

Project objectives are the specific action statements that support the project goals.

Project objectives should always begin with an action verb.

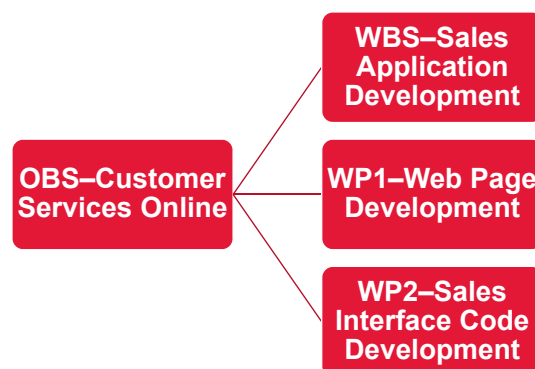


ISACA

19

OBJECT BREAKDOWN STRUCTURE

The object breakdown structure (OBS) represents individual components of the solution and their hierarchical relationship to each other.

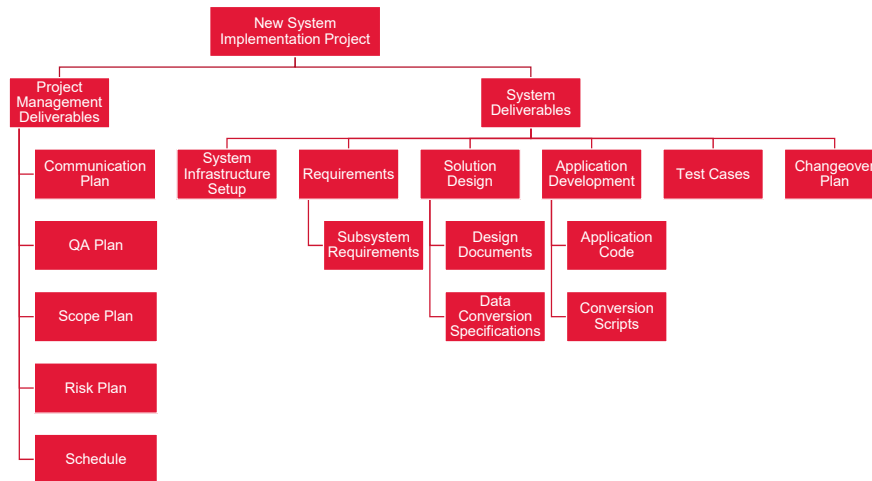


ISACA

20

WORK BREAKDOWN STRUCTURE

The work breakdown structure lists all necessary tasks and groups them into manageable and controllable units.

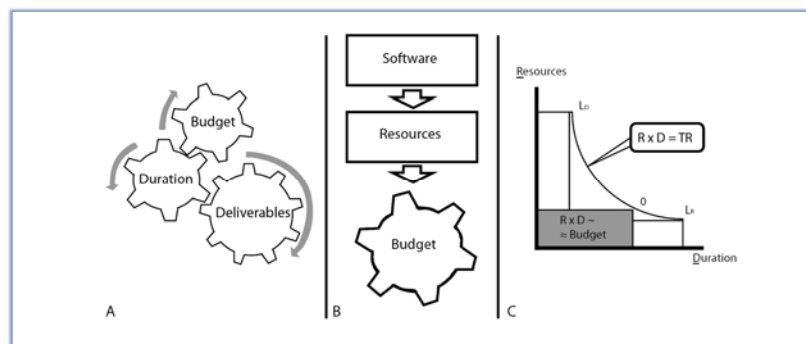


ISACA

21

PROJECT MANAGEMENT ELEMENTS

Overall characteristics of successful project planning are that it is a risk-based management process and iterative in nature.



Source: Personas & Tecnicas Multimedia SL copyright 2009. All rights reserved. Used by permission.

ISACA

22

IS AUDITOR'S ROLE

The IS auditor should review the adequacy of the following project management activities:

- Levels of oversight by project committee/board
- Risk management methods
- Issue management
- Cost management
- Processes for planning and dependency management
- Reporting processes
- Change control processes
- Stakeholder management involvement
- Sign-off process

ISACA

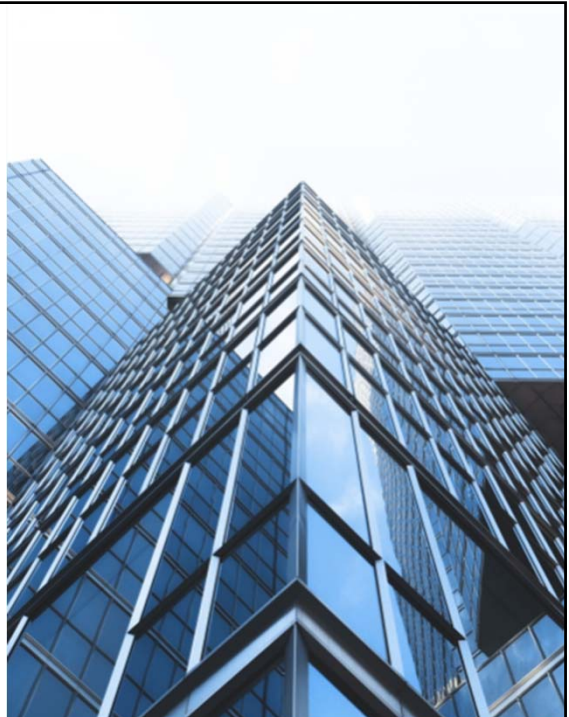
23



ACTIVITY

ABC Corporation is preparing for a major ERP upgrade and related customized code development. You have been selected to perform an IS audit focused on program, project and software development processes.

What is the most important element in evaluating the project management framework?

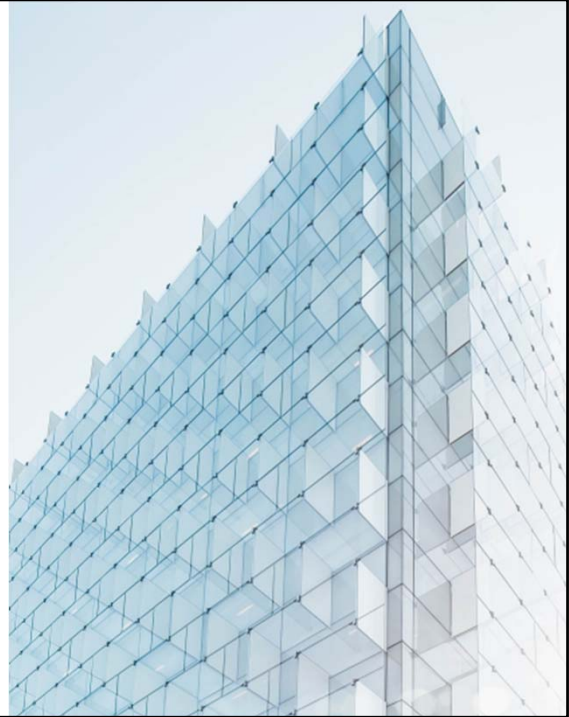


24

DISCUSSION QUESTION

An organization is implementing an enterprise resource planning (ERP) application. Of the following, who is **PRIMARILY** responsible for overseeing the project to ensure that it is progressing in accordance with the project plan and that it will deliver the expected results?

- A. Project sponsor
- B. System development project team (SDPT)
- C. Project steering committee
- D. User project team (UPT)



25

DISCUSSION QUESTION

While evaluating software development practices in an organization, an IS auditor notes that the quality assurance (QA) function reports to project management. The **MOST** important concern for an IS auditor is the:

- A. effectiveness of the QA function because it should interact between project management and user management.
- B. efficiency of the QA function because it should interact with the project implementation team.
- C. effectiveness of the project manager because the project manager should interact with the QA function.
- D. efficiency of the project manager because the QA function will need to communicate with the project implementation team.



26

BUSINESS CASE AND FEASIBILITY

ISACA

27

KEY TERMS

Key Term	Definition
Business case	Documentation of the rationale for making a business investment, used both to support a business decision on whether to proceed with the investment and as an operational tool to support management of the investment through its full economic life cycle
Return on investment (ROI)	A measure of operating performance and efficiency, computed in its simplest form by dividing net income by the total investment over the period being considered

ISACA

28

BUSINESS CASE

A business case provides the information required for an organization to decide whether a project should proceed.

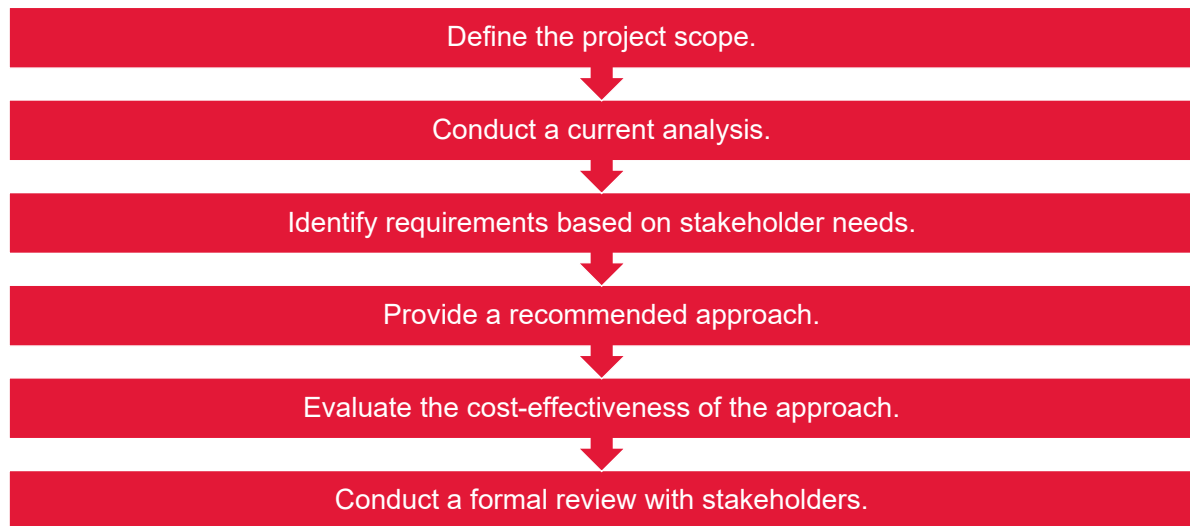
It allows for a comparison of costs and business benefits and provides justification for setting up or continuing a project.

It is often the first step in a project and normally derives from a feasibility study.

ISACA

29

FEASIBILITY STUDY



ISACA

30

IS AUDITOR'S ROLE

During the feasibility study, the IS auditor should perform the following:

- Review the documentation for the phase to ensure that it is reasonable.
- Determine whether all cost justifications/benefits are verifiable and that they show the anticipated costs and expected benefits.
- Identify and determine the criticality of the need.
- Determine if a solution can be achieved with systems already in place. If not, review the evaluation of alternative solutions for reasonableness.
- Determine the suitability of the chosen solution.



31

SYSTEM DEVELOPMENT METHODOLOGIES

ISACA

32

BUSINESS APPLICATION DEVELOPMENT

Organization centric

- The objective of organization-centric applications is to collect, collate, store, archive and share information with business users and various applicable support functions on a need-to-know basis.

End-user-centric

- The objective of an end-user-centric application is to provide different views of data for their performance optimization. This objective includes DSS, geographic information systems (GIS), techniques, etc. Most of these applications are developed using alternative.

33

ISACA

33

KEY TERMS

Key Term	Definition
Computer-aided software engineering (CASE)	The use of software packages that aid in the development of all phases of an information system. System analysis, design programming and documentation are provided. Changes introduced in one CASE chart will update all other related charts automatically. CASE can be installed on a microcomputer for easy access.
System development life cycle (SDLC)	The phases deployed in the development or acquisition of a software system. SDLC is an approach used to plan, design, develop, test and implement an application system or a major modification to an application system. Typical phases of the SDLC include the feasibility study, requirements study, requirements definition, detailed design, programming, testing, installation and post-implementation review.
Waterfall development	Also known as traditional development, a procedure-focused development cycle with formal sign-off at the completion of each level.

ISACA

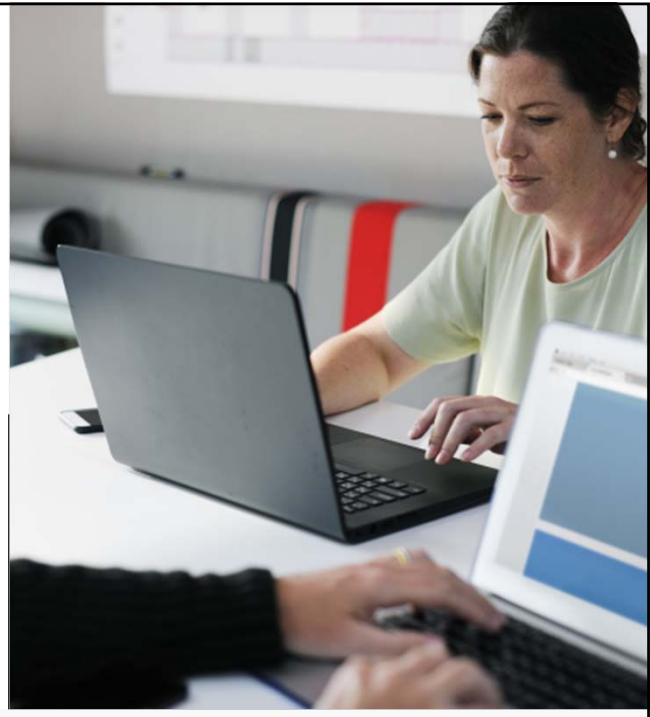
34

SDLC MODELS

Several different SDLC models exist, including:

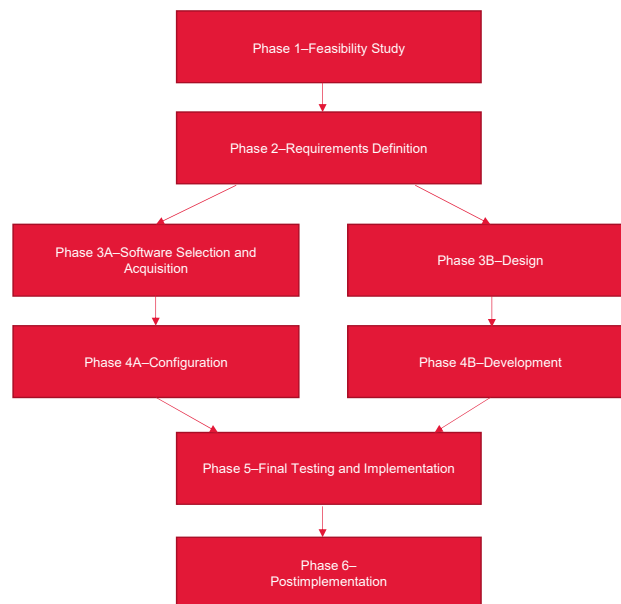
- Traditional waterfall
- V-shaped
- Iterative

35



35

SDLC PHASES



ISACA™

36

SDLC CRITICAL SUCCESS FACTORS

Success factors include:

- Productivity
- Quality
- Economic value
- Customer service

The main advantage of SDLC is that it provides a template into which methods for the requirements can be placed.

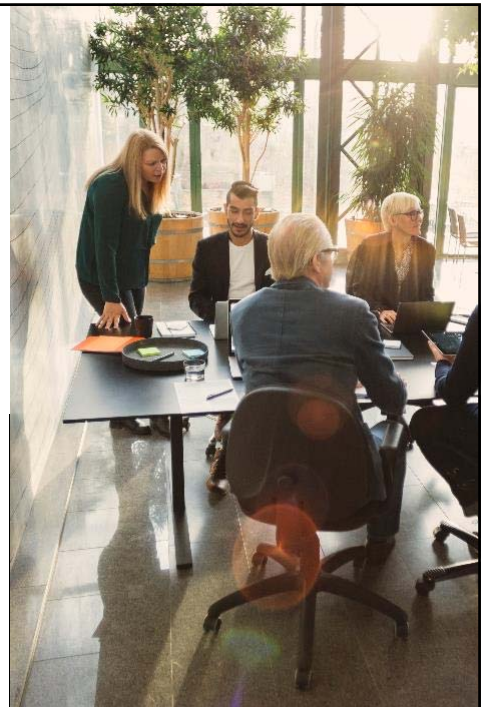
ISACA

37

IS AUDITOR'S ROLE IN SDLC PROJECT MANAGEMENT

When reviewing the SDLC process, an IS auditor should obtain documentation from the various phases and attend project team meetings, offering advice to the project team throughout the system development process.

An IS auditor should also assess the project team's ability to produce key deliverables by the promised dates.



38

IS AUDITOR ROLE IN SDLC (CONT'D)

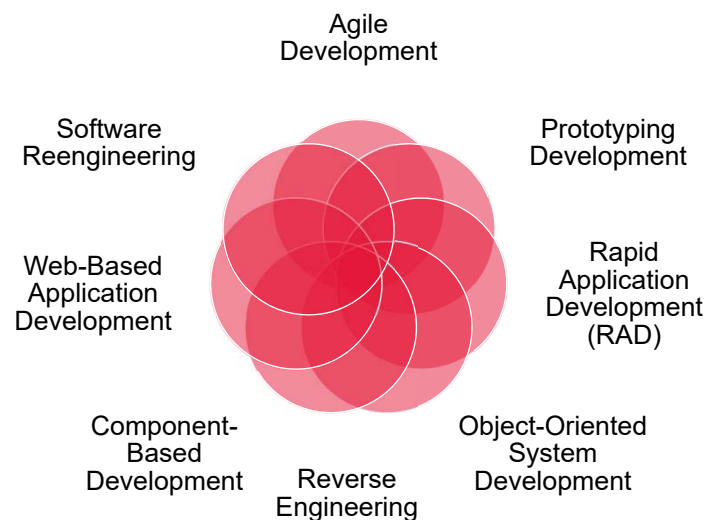
Additionally, adequate and complete documentation of all phases of the SDLC process should be evident. Typical types of documentation include, but should not be limited to, the following:

- Objectives defining what is to be accomplished during that phase
- Key deliverables by phases with project personnel assigned direct responsibilities for these deliverables
- A project schedule with highlighted dates for the completion of key deliverables
- An economic forecast for that phase, defining resources and the cost of the resources required to complete the phase

ISACA

39

SOFTWARE DEVELOPMENT METHODS



ISACA

40

IS AUDITOR'S ROLE IN BUSINESS PROCESS REENGINEERING

When reviewing an organization's BPR efforts, an IS auditor must determine whether:

- The organization's change efforts are consistent with the overall culture and strategic plan of the organization.
- The reengineering team is trying to minimize any negative impact the change might have on the organization's staff.
- The BPR team has documented lessons to be learned after the completion of the BPR/process change project.

An IS auditor would also provide a statement of assurance or conclusion with respect to the objectives of the audit.

ISACA

41

SYSTEM DEVELOPMENT TOOLS

Computer-aided software engineering (CASE)

- Use of automated tools to aid in the software development process. The IS auditor must be able to recognize changes in the development process brought on by CASE and may use CASE as an audit tool.

Code generators

- Tools that generate program code based on parameters defined by a systems analyst or on data/entity flow diagrams developed by the design module of a CASE product. The IS auditor should be aware of source code generated by such tools.

Fourth-generation languages (4GLs)

- Nonprocedural languages that are environmentally independent and have simple language subsets and a workbench approach.

ISACA

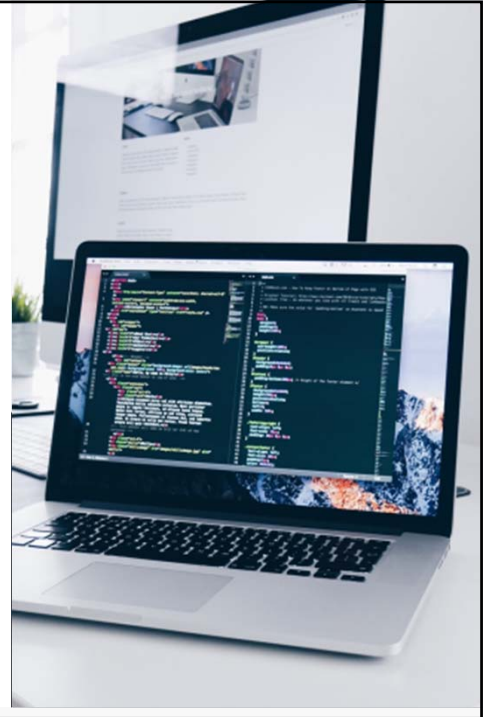
42

IS AUDITOR'S ROLE IN HARDWARE ACQUISITION

When performing an audit of this area, an IS auditor should:

- Determine if the acquisition process began with a business need and whether the hardware requirements for this need were considered in the specifications.
- Determine if several vendors were considered and whether the comparison between them was one according to the criteria:
 - Response time
 - System reaction time
 - Throughput
 - Workload
 - Compatibility
 - Capacity
 - Utilization

43



43



ACTIVITY

The last ERP upgrade encountered significant delays and cost over runs, and the CIO and CFO have requested you to perform an audit of the upcoming ERP upgrade, paying special attention to the integration of the code between enterprises.

What is the development approach designed to achieve easier and more effective integration of code modules within and between enterprises?

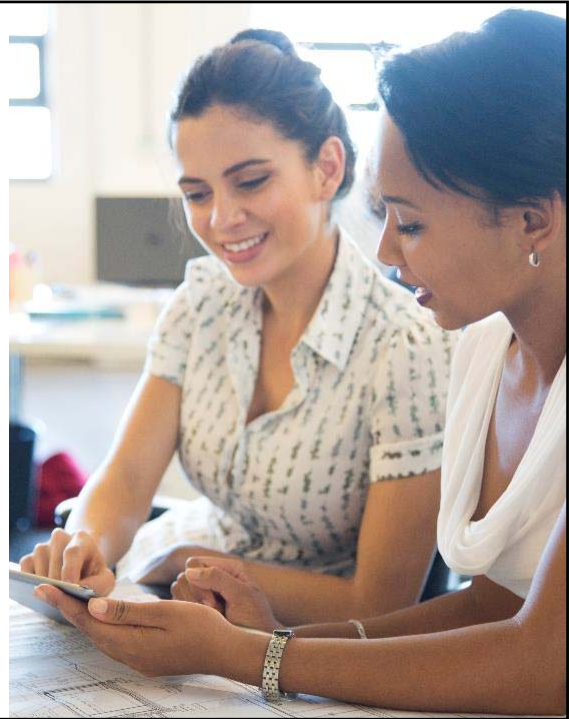


44

DISCUSSION QUESTION

Which of the following would **BEST** help to prioritize project activities and determine the time line for a project?

- A. A Gantt chart
- B. Earned value analysis (EVA)
- C. Program evaluation review technique (PERT)
- D. Function point analysis (FPA)



45

DISCUSSION QUESTION

An IS auditor has found time constraints and expanded needs to be the root causes for recent violations of corporate data definition standards in a new business intelligence project. Which of the following is the **MOST** appropriate suggestion for an auditor to make?

- A. Achieve standards alignment through an increase of resources devoted to the project.
- B. Align the data definition standards after completion of the project.
- C. Delay the project until compliance with standards can be achieved.
- D. Enforce standard compliance by adopting punitive measures against violators.



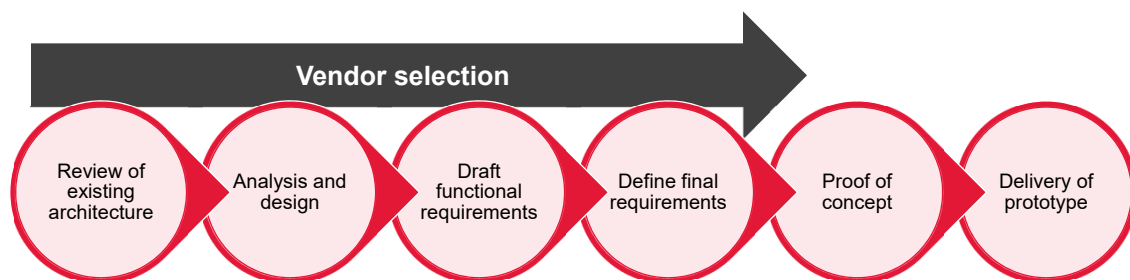
46

INFRASTRUCTURE DEVELOPMENT/ACQUISITION PRACTICES

ISACA

47

PHYSICAL ARCHITECTURE ANALYSIS



ISACA

48

IMPLEMENTATION PLANNING

1. Procurement Phase

- Establish the communication process, and determine the deliverables, contracts and SLAs. Requirements statement is produced.

2. Delivery Time

- Develop delivery plan: priorities, goals, key facts, principles, communication strategies, key indicators, progress on key tasks and responsibilities.

3. Installation Plan

- Develop and review the plan with involved parties.

4. Installation Test Plan

- Develop test plan to include test cases, basic requirements specifications, definition of processes and metrics.

ISACA

49

KEY TERMS

Key Term	Definition
Request for proposal (RFP)	A document distributed to software vendors, requesting them to submit a proposal to develop or provide a software product.
Requirements definition	A technique used in which the affected user groups define the requirements of the system for meeting the defined needs. Some of these are business, regulatory and security-related requirements as well as development-related requirements.

ISACA

50

SYSTEM ACQUISITION FACTORS

Factors impacting whether to develop or acquire a system include:

- The date the system needs to be functional
- The cost to develop the system as opposed to buying it
- The resources, staff and hardware required
- In a vendor system, the license characteristics (e.g., yearly renewal, perpetual) and maintenance costs
- Other systems that will need the ability to interface with the new system
- Compatibility with strategic business plans, risk appetite, regulatory compliance requirements and the organization's IT infrastructure
- Likely future requirements for changes to functionality

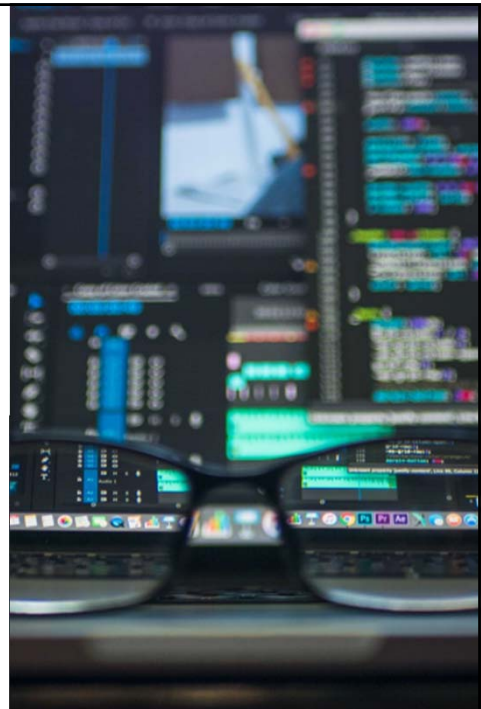
ISACA

51

SYSTEM SPECIFICATIONS

When acquiring a new system, the specifications should include the following:

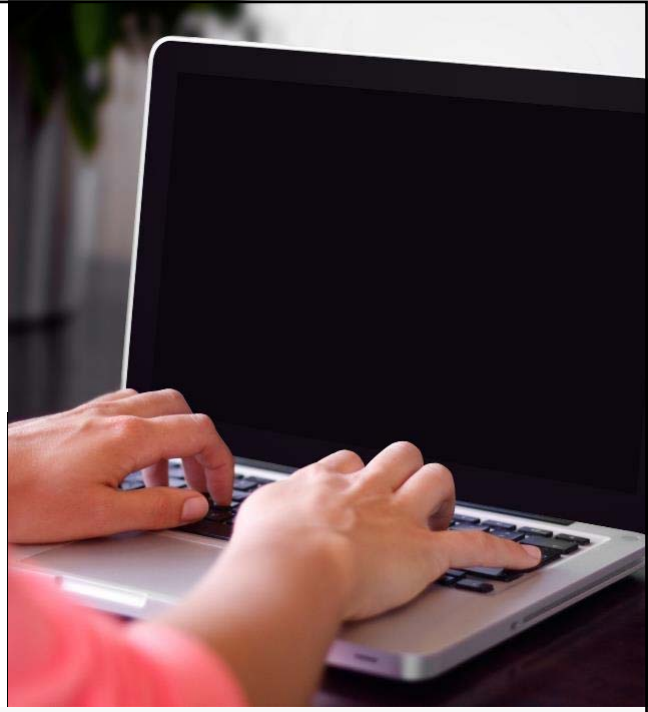
- Organizational description (centralized/decentralized, distributed, outsourced, manned or lights-out)
- Hardware and software evaluation assurance levels for security robustness
- Information processing requirements
- Hardware requirements
- System software applications
- Support requirements
- Adaptability and conversion requirements
- System constraints



52

REQUIREMENTS DEFINITION

Requirements definition should include descriptions of what a system should do, how users will interact with a system, conditions under which the system will operate and the information criteria the system should meet.



53

REQUIREMENTS DEFINITION (CONT'D)

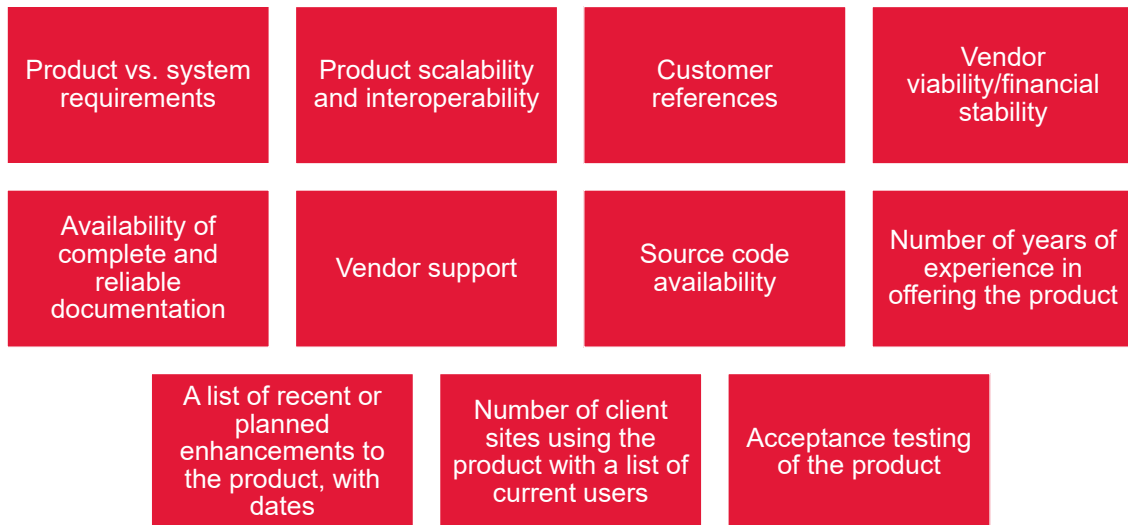
In order to successfully complete a requirements definition, the project team will complete tasks such as:

- Identify stakeholders.
- Record requirements in a structured format and consult with stakeholders.
- Verify requirements are complete, consistent, unambiguous, verifiable, modifiable, testable and traceable.
- Detect and correct conflicts.
- Identify any constraints.
- Resolve conflicts.

ISACA

54

REQUEST FOR PROPOSAL (RFP)



ISACA

55

SOFTWARE ACQUISITION PROCESS

During software acquisition, the IS auditor should perform the following:

- Analyze the documentation from the feasibility study to determine whether the decision to acquire a solution was appropriate.
- Review the RFP to ensure that it covers the items listed and whether the selected vendor is supported by the RFP documentation.
- Attend agenda-based presentations and conference room pilots to ensure that the system matches the vendor's response to the RFP.
- Review the vendor contract prior to its signing.
- Ensure the contract is reviewed by legal counsel before it is signed.

ISACA

56

IS AUDITOR'S ROLE IN HARDWARE ACQUISITION

When performing an audit of this area, an IS auditor should:

- Determine if the acquisition process began with a business need and whether the hardware requirements for this need were considered in the specifications.
- Determine if several vendors were considered and whether the comparison between them was done according to the aforementioned criteria.

57



57

IS AUDITOR'S ROLE IN SOFTWARE ACQUISITION

An IS auditor should perform the following when reviewing software acquisition:

- Analyze the documentation from the feasibility study to determine whether the decision to acquire a solution was appropriate (including consideration of common criteria evaluations).
- Review the RFP to ensure that it covers the items listed in this section.
- Determine whether the selected vendor is supported by RFP documentation.
- Attend agenda-based presentations and conference room pilots to ensure that the system matches the vendor's response to the RFP.
- Review the vendor contract prior to its signing to ensure that it includes the items listed.
- Ensure the contract is reviewed by legal counsel before it is signed.
- Review the RFP to ensure security responses are included by the vendor.

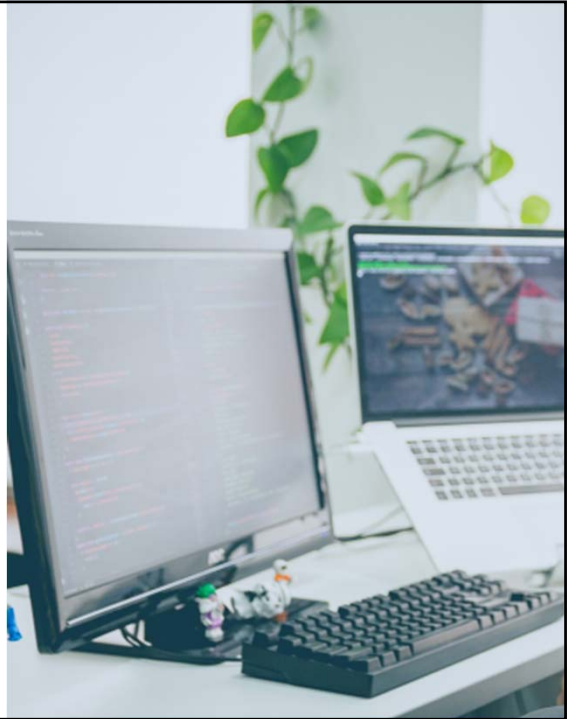
ISACA

58

DISCUSSION QUESTION

During the audit of an acquired software package, an IS auditor finds that the software purchase was based on information obtained through the Internet, rather than from responses to a request for proposal (RFP). The IS auditor should **FIRST**:

- A. test the software for compatibility with existing hardware.
- B. perform a gap analysis.
- C. review the licensing policy.
- D. ensure that the procedure had been approved.

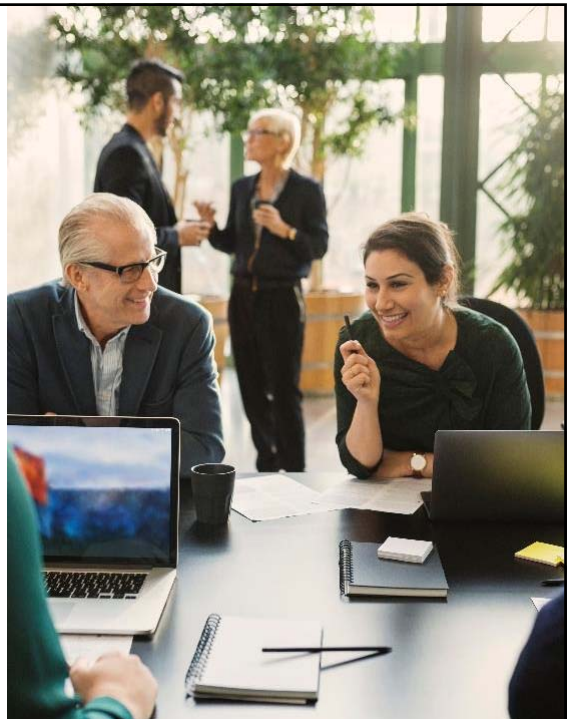


59

DISCUSSION QUESTION

A company has contracted with an external consulting firm to implement a commercial financial system to replace its existing system developed in-house. In reviewing the proposed development approach, which of the following would be of **GREATEST** concern?

- A. Acceptance testing is to be managed by users.
- B. A quality plan is not part of the contracted deliverables.
- C. Not all business functions will be available on initial implementation.
- D. Prototyping is being used to confirm that the system meets business requirements.



60

CONTROL IDENTIFICATION

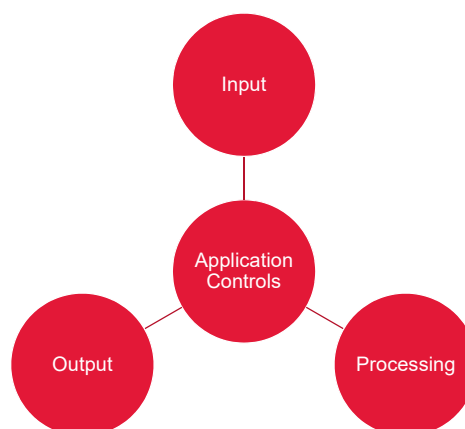
ISACA

61

APPLICATION CONTROLS

Application controls ensure that:

- Only complete, accurate and valid data are entered and updated in a computer system.
- Processing accomplishes the correct task.
- Processing results meet expectations.
- Data are maintained.

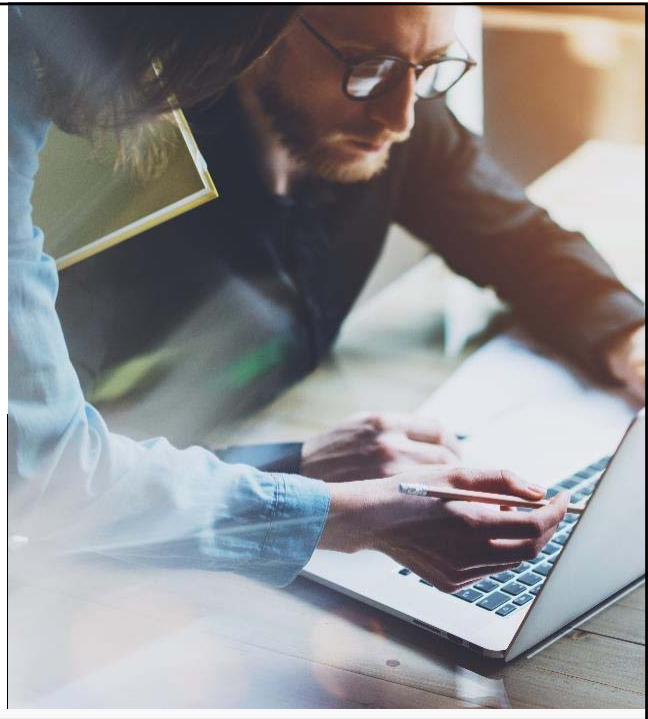


ISACA

62

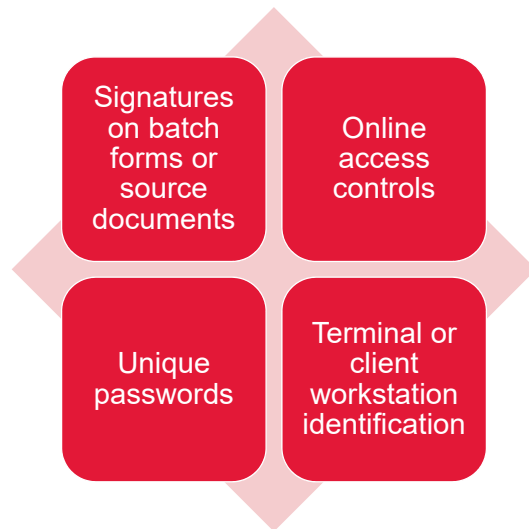
INPUT CONTROLS

Input controls ensure that only valid and authorized information are input and that these transactions are only processed once.



63

TYPES OF SIGNATURE AUTHORIZATION

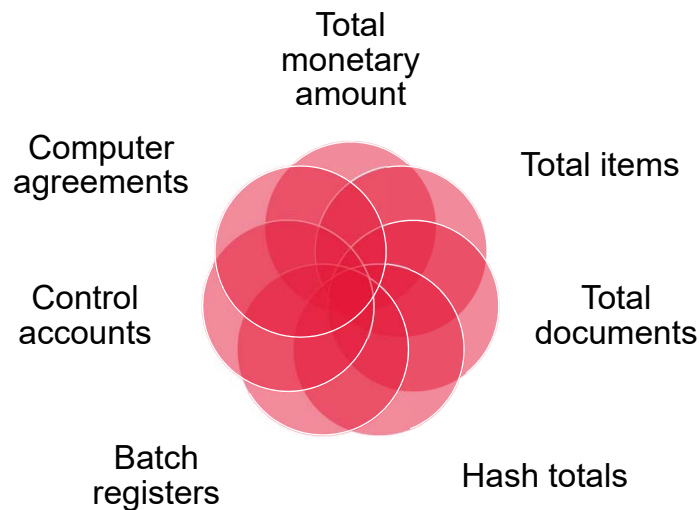


Input authorization verifies that all transactions have been authorized and approved by management.

ISACA

64

BATCH CONTROLS AND BALANCING



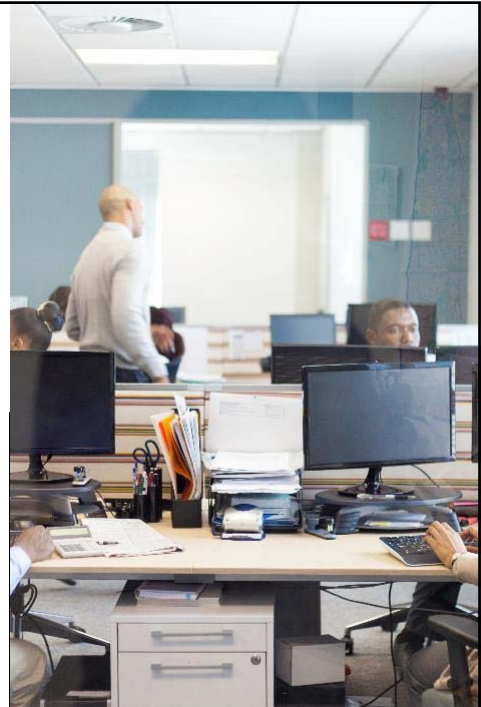
ISACA

65

ERROR REPORTING AND HANDLING

Input error handling verifies that only correct data is accepted into a system. It can be processed by the following:

- Rejecting only transactions with errors
- Rejecting the whole batch of transactions
- Holding the batch in suspense
- Accepting the batch and flagging error transactions



66

PROCESSING PROCEDURES AND CONTROLS

Processing procedures and controls are meant to ensure the reliability of application program processing.

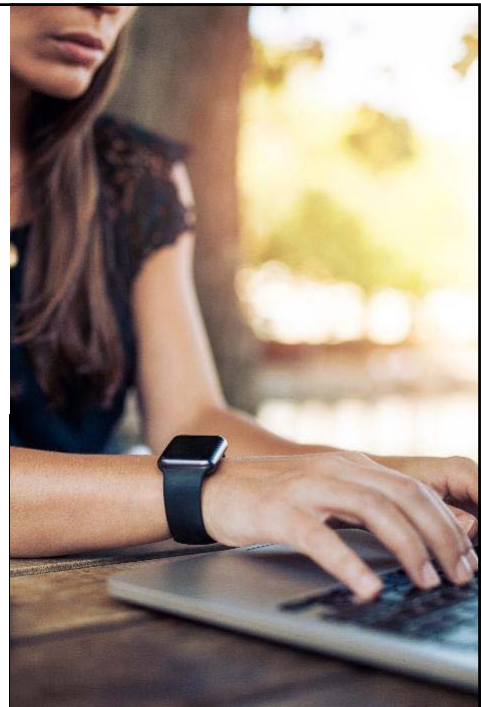


67

DATA VALIDATION AND EDITING PROCEDURES

Data validation and editing procedures ensure that input data are validated and edited as close to the time and point of origination as possible.

- Sequence check
- Limit check
- Range check
- Validity check
- Reasonableness check
- Table lookups
- Existence check
- Key verification
- Check digit
- Completeness check
- Duplicate check
- Logical relationship check



68

PROCESSING CONTROLS

Processing controls are meant to ensure the completeness and accuracy of accumulated data.

- Manual recalculations
- Editing
- Run-to-run totals
- Programmed controls
- Reasonableness verification of calculated amounts
- Limit checks on amounts
- Reconciliation of file totals
- Exception reports

ISACA

69

DATA FILE CONTROL PROCEDURES

Data file controls ensure that only authorized processing occurs to stored data.

- Before and after image reporting
- Maintenance error reporting and handling
- Source documentation retention
- Internal and external labeling
- Version usage
- Data file security
- One-for-one checking
- Prerecorded input
- Transaction logs
- File updating and maintenance authorization
- Parity checking

ISACA

70

OUTPUT CONTROLS

Output controls provide assurance that the data delivered to users will be presented, formatted and delivered in a consistent and secure manner.

- Logging and storage of negotiable, sensitive and critical forms in a secure place
- Computer generation of negotiable instruments, forms and signatures
- Report accuracy, completeness and timeliness
- Reports generated from the system
- Report distribution
- Balancing and reconciling
- Output error handling
- Output report retention
- Verification of receipt of reports

ISACA

71

IS AUDITOR'S ROLE IN REVIEWING APPLICATION CONTROLS

The IS auditor's tasks include the following:

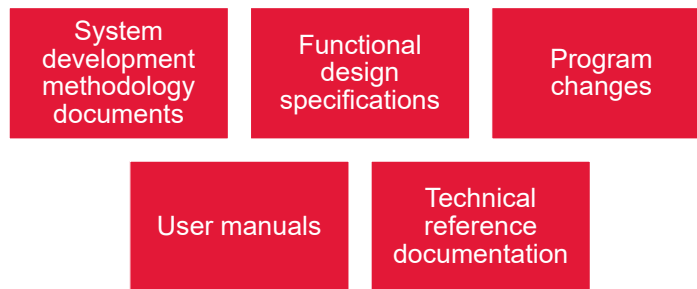
- Identifying significant application components and the flow of transactions
- Identifying the application control strengths and evaluating the impact of the control weaknesses
- Developing a testing strategy
- Testing the controls to ensure their functionality and effectiveness
- Evaluating the control environment by analyzing the test results and other audit evidence to determine that control objectives were achieved
- Considering the operational aspects of the application to ensure its efficiency and effectiveness

ISACA

72

APPLICATION CONTROL DOCUMENTATION

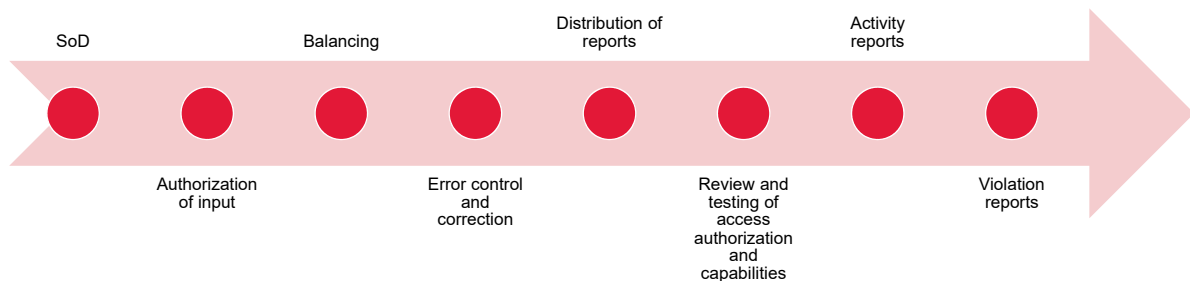
The IS auditor should review the following documentation to gain an understanding of the application's development:



ISACA

73

USER PROCEDURES



74

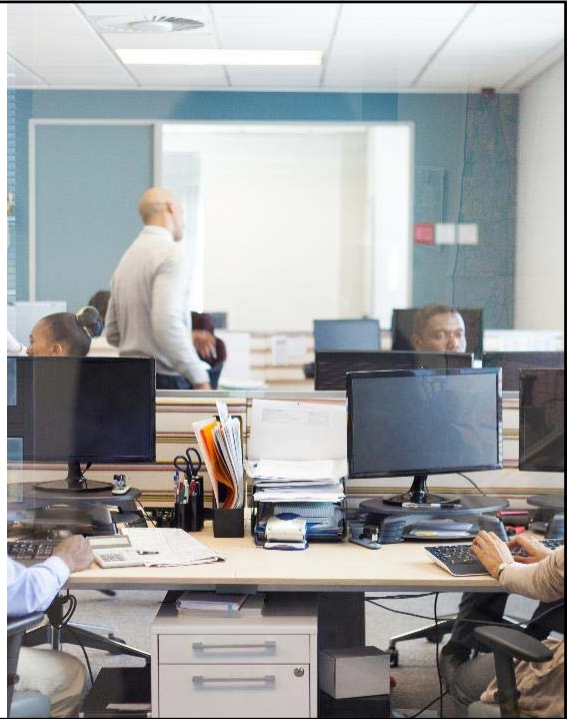
ISACA

74

ACTIVITY

You will provide interim reports and other documentation during critical phases within the project life cycle to allow the project team to respond to any significant findings that could pose a risk to the project's success.

What is documented in specifications and drawings describing the reference infrastructure that will be used by all projects downstream?



75

DISCUSSION QUESTION

Which of the following would be the **BEST** approach to ensure that sufficient test coverage will be achieved for a project with a strict end date and a fixed time to perform testing?

- A. Requirements should be tested in terms of importance and frequency of use.
- B. Test coverage should be restricted to functional requirements.
- C. Automated tests should be performed through the use of scripting.
- D. The number of required test runs should be reduced by retesting only defect fixes.



76

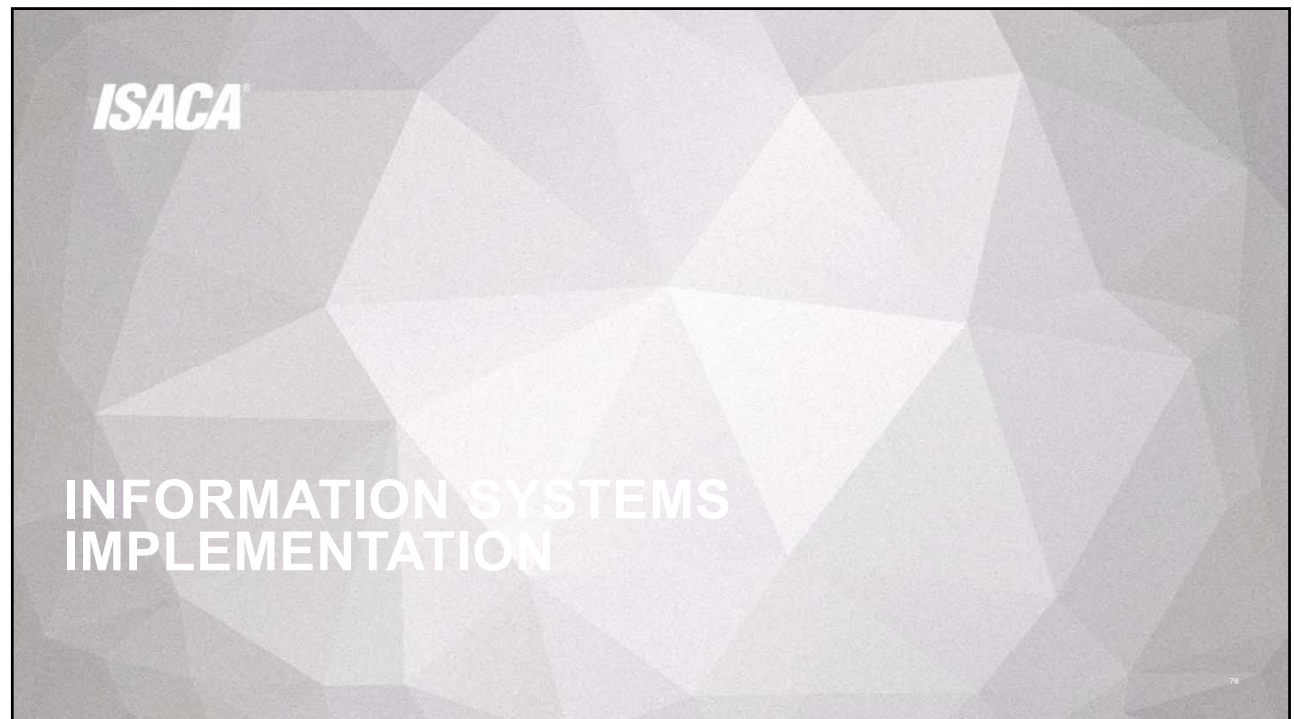
DISCUSSION QUESTION

Who should review and approve system deliverables as they are defined and accomplished to ensure the successful completion and implementation of a new business system application?

- A. User management
- B. Project steering committee
- C. Senior management
- D. Quality assurance staff



77



78

TESTING METHODOLOGIES

ISACA

79

TESTING CLASSIFICATIONS

Unit testing

- Tests program logic within a particular program or module
- Ensures that the internal operation of the program performs according to specification
- Uses a set of test cases that focus on the control structure of the procedural design

Interface or integration testing

- A hardware or software test that evaluates the connection of two or more components that pass information from one area to another

System testing

- A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly

Final acceptance testing

- System testing that takes place during the implementation phase and applies the organization's QA methodology

ISACA

80

FINAL ACCEPTANCE TESTING

Quality Assurance Testing (QAT)

- Focuses on technical aspects of the application
- Verifies that the application works as documented by testing the logical design and the technology itself
- Ensures that the application meets the documented technical specifications and deliverables
- Involves minimal end-user participation
- Performed by IT department

User Acceptance Testing (UAT)

- Focuses on functional aspect of the application
- Ensures that the system is production-ready and satisfies all documented requirements
- Performed in a secure testing or staging environment that mimics production as close as possible
- Tests are written from a user's perspective
- Performed by the IT department and the end user

ISACA

81

OTHER TYPES OF TESTING

Test Type	Description
Alpha and beta testing	The first stage, called alpha testing, is often performed on an early version of the application system only by users within the organization developing the software (i.e., systems testing). The second stage, called beta testing, a form of user acceptance testing, generally involves a limited number of external users and involves real-world exposure.
Pilot testing	A preliminary test that focuses on specific and predetermined aspects of a system, such as a proof of concept.
White box testing	A testing approach that uses knowledge of a program/module's underlying implementation and code intervals to verify its expected behavior.
Black box testing	A testing approach that focuses on the functionality of the application or product and does not require knowledge of the code intervals.

ISACA

82

OTHER TYPES OF TESTING (CONT'D)

Test Type	Description
Function/validation testing	Tests the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements
Regression testing	The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors
Parallel testing	The process of feeding test data into two systems—the modified system and an alternative system (possibly the original system)—and comparing the results
Sociability testing	Test to confirm that the new or modified system can operate in its target environment without adversely impacting existing systems

ISACA

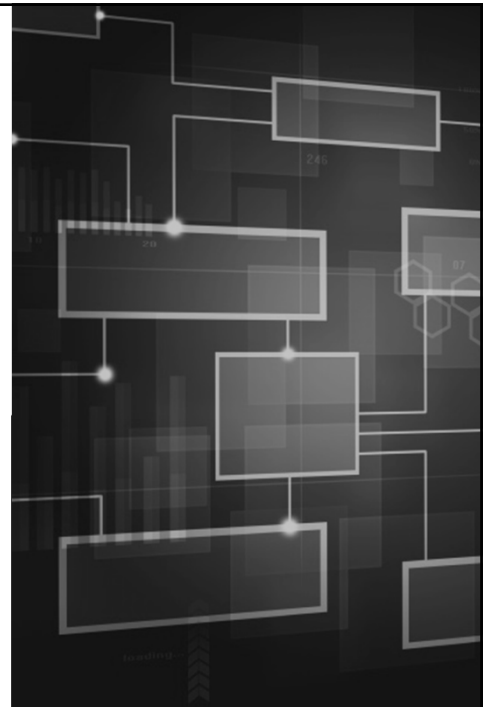
83

SOFTWARE TESTING

Testing determines that the user requirements have been validated, the system is performing as anticipated and internal controls work as intended.

The two primary approaches to testing include:

- Bottom up—Begin testing of individual units, and work upward until a complete system testing has taken place.
- Top down—Begin testing the complete system, and work downward to individual units.



84

APPLICATION SYSTEM TESTING

Snapshot	Integrated testing facility
Mapping	Parallel simulation
Tracing and tagging	Transaction selection programs
Test data/deck	Embedded audit data collection
Base-case system evaluation	Extended records
Parallel operation	

ISACA

85

DATA INTEGRITY TESTING

Relational integrity tests

- Data validation routines performed at the data element and record-based levels.

Referential integrity tests

- Define existence relationships between entities in different tables of a database that needs to be maintained by the DBMS.

ISACA

86

IS AUDITOR'S ROLE

During testing, the IS auditor should perform the following:

- Review the test plan, error reports, end user documentation and procedures used for completeness and accuracy.
- Reconcile control totals and converted data.
- Verify cyclical processing and critical reports for accuracy.
- Interview end users of the system for their understanding of new methods, procedures and operating instructions.
- Verify that system security is functioning as designed.
- Review parallel testing results and the user acceptance testing.
- Review unit and system test plans to determine whether tests for internal controls are planned and performed.
- Review the user acceptance testing and ensure that the accepted software has been delivered to the implementation team. The vendor should not be able to replace this version.
- Review procedures used for recording and following through on error reports.

ISACA

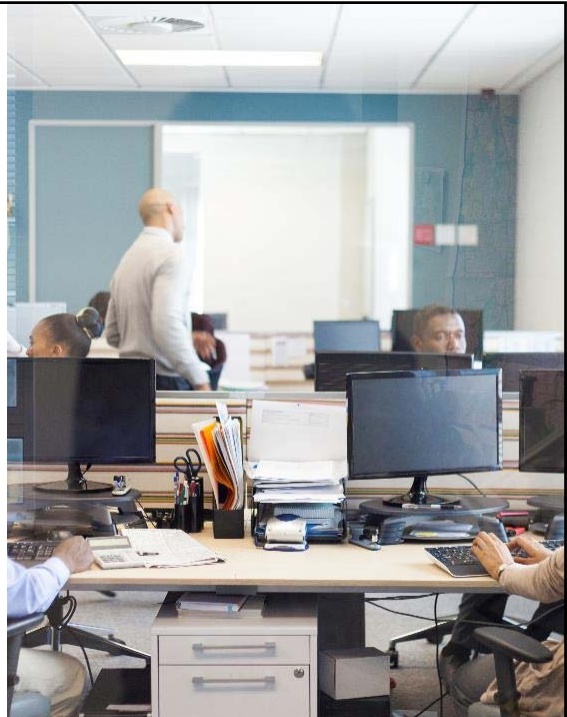
87



ACTIVITY

The time has arrived for you to make a recommendation to management on whether the system is ready to go into live production. You will rely heavily on testing results to help you make your recommendation.

What type of hardware or software test evaluates the connection of two or more components that pass information from one area to another?

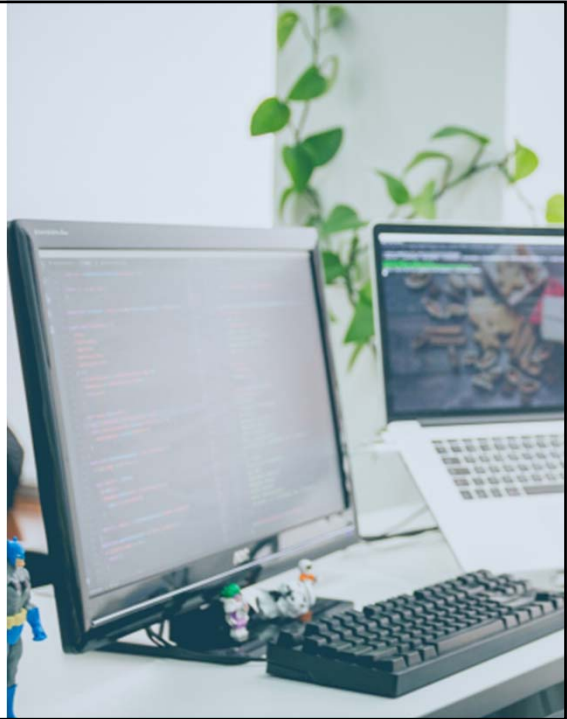


88

DISCUSSION QUESTION

An IS auditor is reviewing the software development process for an organization. Which of the following functions would be appropriate for the end users to perform?

- A. Program output testing
- B. System configuration
- C. Program logic specification
- D. Performance tuning

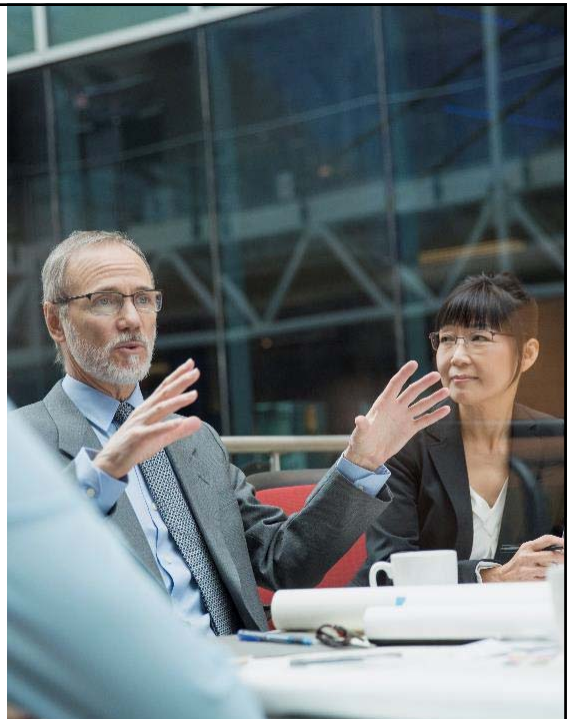


89

DISCUSSION QUESTION

From a risk management point of view, the **BEST** approach when implementing a large and complex IT infrastructure is:

- A. a major deployment after proof of concept.
- B. prototyping and a one-phase deployment.
- C. a deployment plan based on sequenced phases.
- D. to simulate the new infrastructure before deployment.



90

CONFIGURATION RELEASE MANAGEMENT

ISACA

91

CONFIGURATION RELEASE MANAGEMENT

Changes to IT systems must be carefully assessed, planned, tested, approved, documented and communicated to minimize any undesirable consequences to the business processes.

An IS auditor should be aware of the tools available for managing configuration, change and release management and of the controls in place to ensure SoD between development staff and the production environment.

Management support
of this process is
critical for success

ISACA

92

SUPPORTING CHANGE MANAGEMENT

Configuration management tools will support change management and release management through the:

- Identification of items affected by a proposed change to assist with impact assessment (functional, operational and security)
- Recording configuration items affected by authorized changes
- Implementation of changes in accordance with authorization records
- Registering of configuration item changes when authorized changes and releases are implemented
- Recording of baselines that are related to releases (with known consequences) to which an organization would revert if an implemented change fails
- Preparing a release to avoid human errors and resource costs

93

The configuration management process is implemented by developing and following a configuration management plan and operating procedures.

ISACA

93

SYSTEM MIGRATION, INFRASTRUCTURE DEPLOYMENT AND DATA CONVERSION

94

ISACA

94

DATA MIGRATION

The data conversion process must provide some means, such as audit trails and logs, which allow for the verification of the accuracy and completeness of the converted data.

This verification of accuracy and completeness may be performed through a combination of manual processes, system utilities, vendor tools and one-time-use special applications.

95

ISACA

95

PLANNING THE MIGRATION

The data migration project should be carefully planned and use appropriate methodologies and tools to minimize the risk of:

- Disruption of routine operations
- Violation of the security and confidentiality of data
- Conflicts and contention between legacy and migrated operations
- Data inconsistencies and loss of data integrity during the migration process

96

ISACA

96

IMPLEMENTATION PLANNING

After successful testing, the system is implemented according to the organization's change control procedures.

An implementation plan should be prepared well in advance of the implementation date.

Each step of setting up the production environment should be documented, including who will be responsible, how the step will be verified and the back-out procedure.

Implementing a Fallback (Rollback) Scenario

ISACA

97

CHANGEOVER (GO-LIVE OR CUTOVER) TECHNIQUES

Parallel Changeover

Phased Changeover

Abrupt Changeover

98



98

SYSTEM IMPLEMENTATION

An IS auditor should verify that appropriate sign-offs have been obtained prior to implementation and perform the following:

- Review the programmed procedures used for scheduling and running the system along with system parameters used in executing the production schedule.
- Review all system documentation to ensure its completeness and that all recent updates from the testing phase have been incorporated.
- Verify all data conversion to ensure that they are correct and complete before implementing the system in production.

99

ISACA

99

IMPLEMENTATION PLANNING

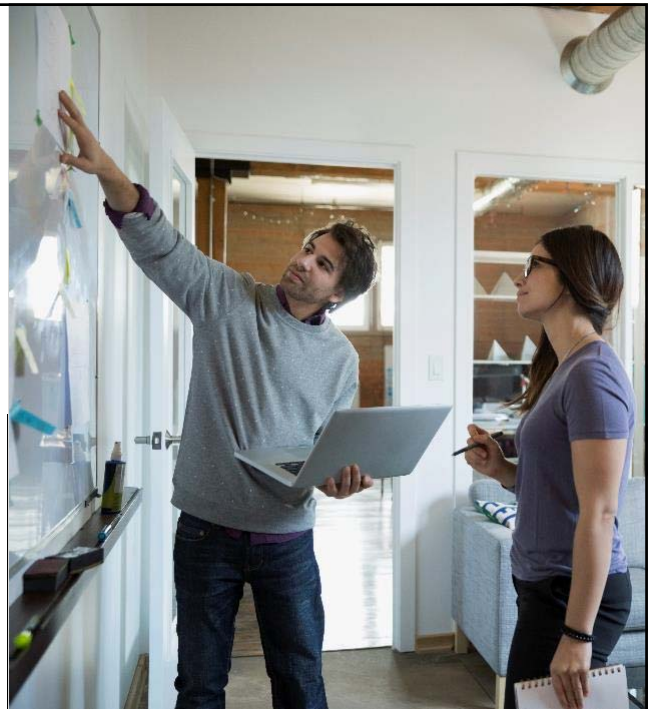
Establish roles

Acquire and train necessary skills

Distribute workload based on roles and responsibilities

Create a phased transition plan

100



100

SYSTEM CHANGE PROCEDURES AND THE PROGRAM MIGRATION PROCESS

After implementation is completed the IS auditor should consider the following:

- The existence and use of a methodology for authorizing, prioritizing and tracking system change requests from the user
- Whether emergency change procedures are addressed in the operations manuals
- Whether change control is a formal procedure for the user and the development groups
- Whether the change control log ensures all changes shown were resolved
- The user's satisfaction with the turnaround—timeliness and cost—of change requests
- The adequacy of the security access restrictions over production source and executable modules
- The adequacy of the organization's procedures for dealing with emergency program changes
- The adequacy of the security access restrictions over the use of the emergency logon IDs

IS auditor should review the overall change management process for possible improvements in acknowledgement, response time, response effectiveness and user satisfaction with the process.

ISACA

101

POST-IMPLEMENTATION

Post-implementation reviews are typically conducted after the project has been in use long enough to realize its business benefits and costs and to measure the project's overall success and impact on the business units.

Metrics include:

- Total cost of ownership (TCO)
- Return on investment (ROI)

ISACA

102

POST-IMPLEMENTATION REVIEW

During the post-implementation review, the IS auditor should perform the following:

- Determine if the system's objectives and requirements were achieved.
- Determine if the cost benefits are being measured, analyzed and accurately reported to management.
- Review program change requests performed to assess the type of changes required of the system.
- Review controls to ensure that they are operating according to design.
- Review operators' error logs to determine if there are any resource or operating problems.
- Review input and output control balances and reports to verify that the system is processing data accurately.

ISACA

103

PROJECT CLOSE

Assign outstanding issues.

Assign custody of contracts.

Archive or hand off documentation.

Discuss lessons learned.

Conduct a post-project review.

ISACA

104

CERTIFICATION AND ACCREDITATION

Certification is a process by which an assessor performs a comprehensive assessment against a standard of management and operational and technical controls and determines the level of compliance.

- The goal is to determine the extent to which controls are implemented correctly, operating as intended and producing the desired outcome.

Accreditation authorizes operation of an information system, thereby accepting the risk. A senior official accepts responsibility and is fully accountable for any adverse impacts.

ISACA

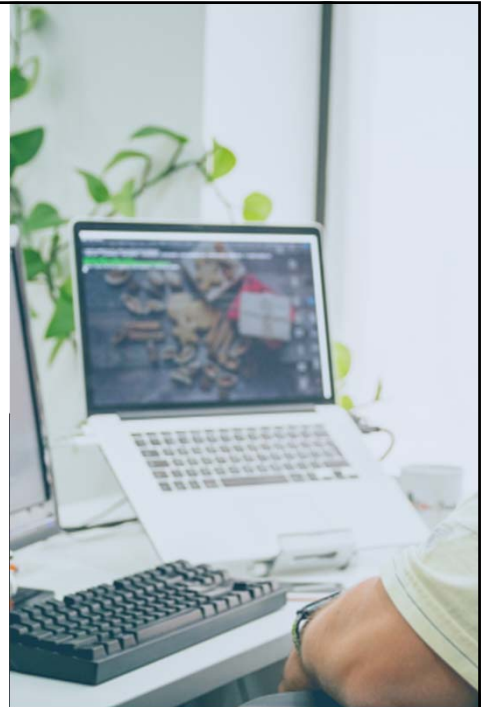
105

SYSTEM MAINTENANCE

Following implementation, a system enters into the ongoing development or maintenance stage.

System maintenance practices refer primarily to the process of managing change to application systems while maintaining the integrity of both the production and application source and executable code.

A standard change management process needs to be in place for recording and performing changes, which is typically established during the project design phase.



106

IS AUDITOR'S ROLE

Determine if the system's objectives and requirements were achieved.

Determine if the cost benefits identified in the feasibility study are being measured, analyzed and accurately reported to management.

Review program change requests performed to assess the type of changes required of the system.

Review controls built into the system to ensure that they are operating according to design.

Review operators' error logs to determine if there are any resource or operating problems inherent within the system.

Review input and output control balances and reports to verify that the system is processing data accurately.

ISACA

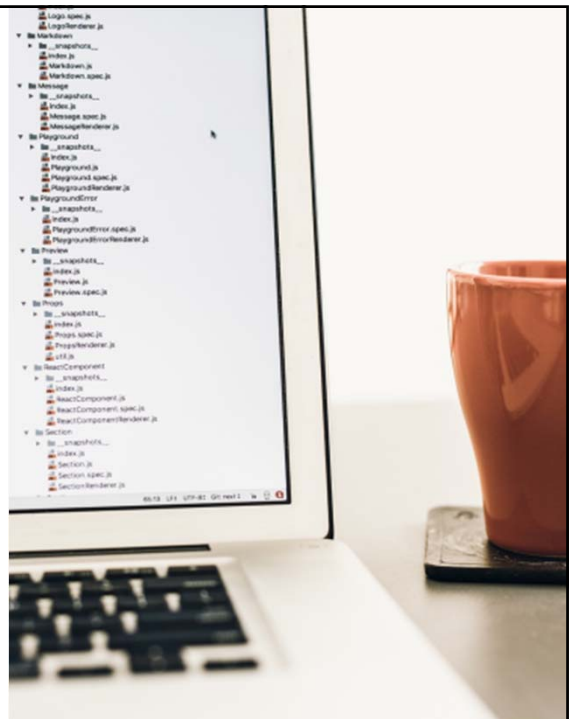
107



ACTIVITY

The audit has been challenging, but now the ERP upgrade project is completed. The new system is stabilized in production. It is time for you to complete the postimplementation review.

What is the most important task to address during the post-implementation review?

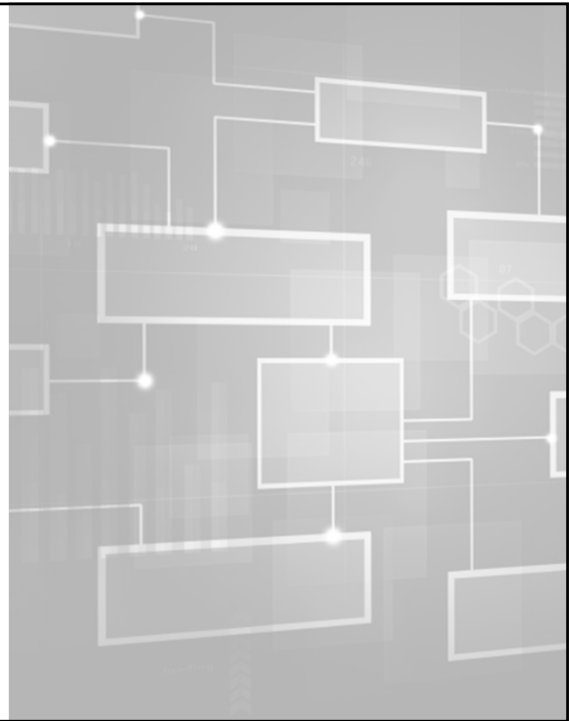


108

DISCUSSION QUESTION

During a postimplementation review, which of the following activities should be performed?

- A. User acceptance testing (UAT)
- B. Return on investment (ROI) analysis
- C. Activation of audit trails
- D. Updates of the state of enterprise architecture (EA) diagrams

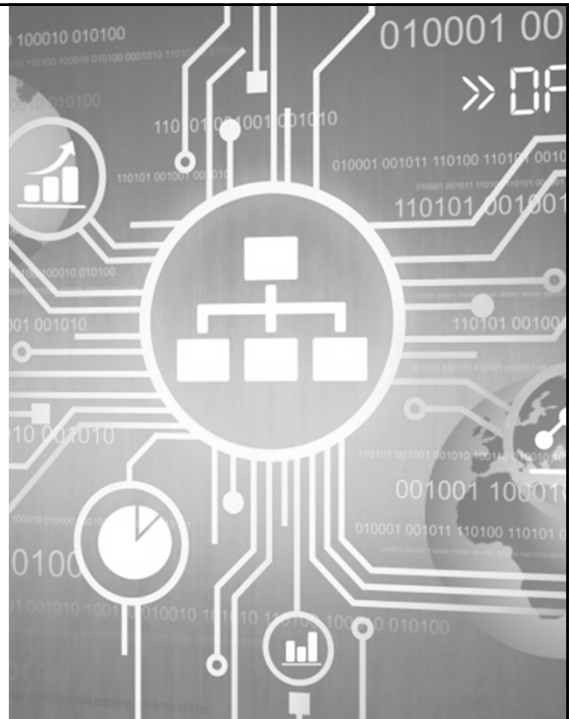


109

DISCUSSION QUESTION

The **PRIMARY** objective of conducting a postimplementation review for a business process automation project is to:

- A. ensure that the project meets the intended business requirements.
- B. evaluate the adequacy of controls.
- C. confirm compliance with technological standards.
- D. confirm compliance with regulatory requirements.



110

DISCUSSION QUESTION

A legacy payroll application is migrated to a new application. Which of the following stakeholders should be **PRIMARILY** responsible for reviewing and signing-off on the accuracy and completeness of the data before going live?

- A. IS auditor
- B. Database administrator
- C. Project manager
- D. Data owner

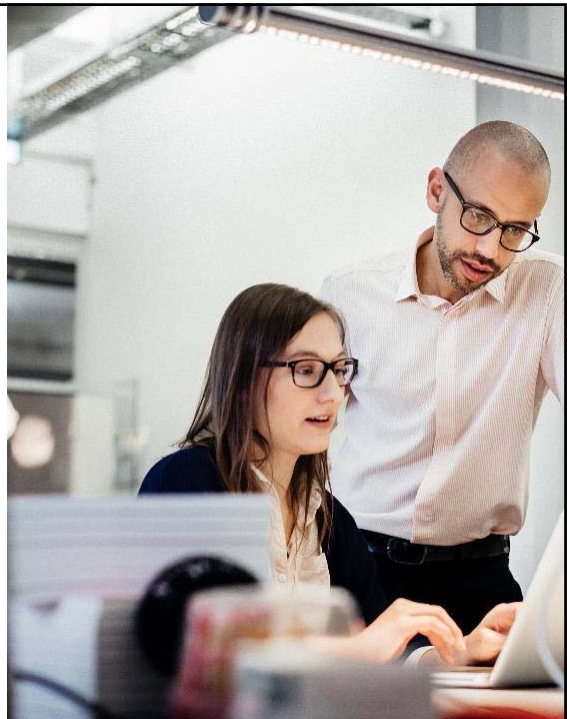


111

DISCUSSION QUESTION

An IS auditor should ensure that review of online electronic funds transfer (EFT) reconciliation procedures should include:

- A. vouching.
- B. authorizations.
- C. corrections.
- D. tracing.



112

PRACTICE QUESTIONS

ISACA

113

PRACTICE QUESTION

The reason for establishing a stop or freezing point on the design of a new system is to:

- A. prevent further changes to a project in process.
- B. indicate the point at which the design is to be completed.
- C. require that changes after that point be evaluated for cost-effectiveness.
- D. provide the project management team with more control over the project design.



114

PRACTICE QUESTION

During the audit of an acquired software package, an IS auditor finds that the software purchase was based on information obtained through the Internet, rather than from responses to a request for proposal. The IS auditor should **FIRST**:

- A. test the software for compatibility with existing hardware.
- B. perform a gap analysis.
- C. review the licensing policy.
- D. ensure that the procedure had been approved.

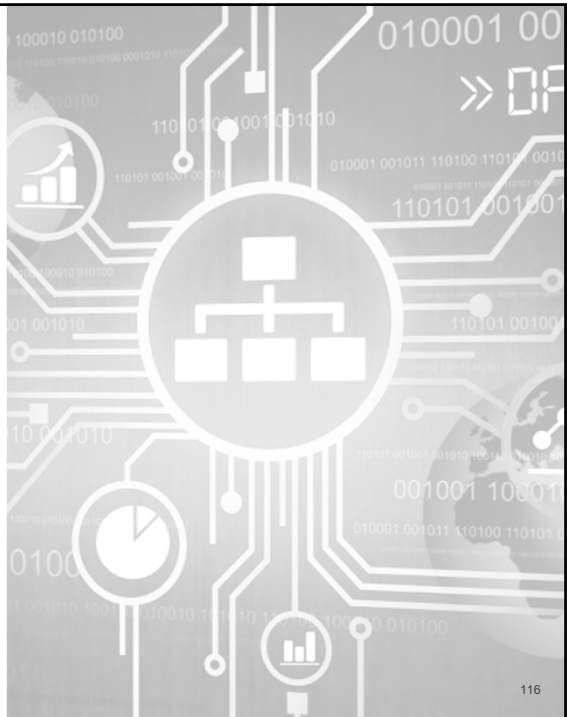


115

PRACTICE QUESTION

The phases and deliverables of a system development life cycle project should be determined:

- A. during the initial planning stages of the project.
- B. after early planning has been completed but before work has begun.
- C. throughout the work stages, based on risk and exposures.
- D. only after all risk and exposures have been identified and the IS auditor has recommended appropriate controls.

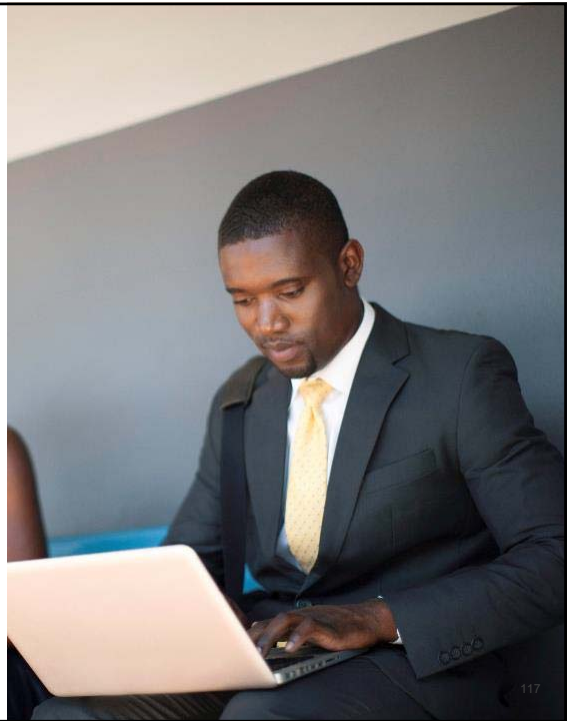


116

PRACTICE QUESTION

Ideally, stress testing should be carried out in a:

- A. test environment using test data.
- B. production environment using live workloads.
- C. test environment using live workloads.
- D. production environment using test data.

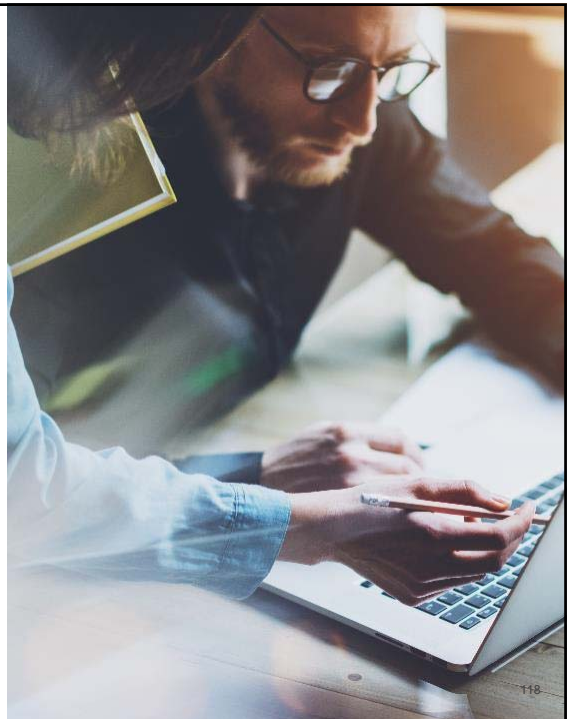


117

PRACTICE QUESTION

Change control for business application systems being developed using prototyping could be complicated by the:

- A. iterative nature of prototyping.
- B. rapid pace of modifications in requirements and design.
- C. emphasis on reports and screens.
- D. lack of integrated tools.

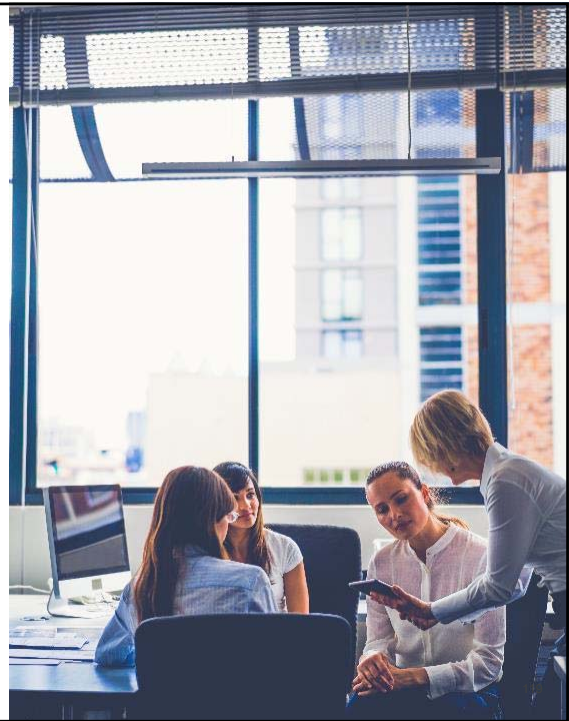


118

PRACTICE QUESTION

The **BEST** time for an IS auditor to assess the control specifications of a new application software package which is being considered for acquisition is during:

- A. the internal lab testing phase.
- B. testing and prior to user acceptance.
- C. the requirements gathering process.
- D. the implementation phase.



119

DOMAIN 3 REVIEW

As an IS auditor, you should now be able to able to:

- Evaluate whether the business case for proposed changes to information systems meet business objectives.
- Evaluate the organization's project management policies and practices.
- Evaluate controls at all stages of the information systems development lifecycle.
- Evaluate the readiness of information systems for implementation and migration into production.
- Conduct post-implementation review of systems to determine whether project deliverables, controls, and requirements are met.
- Evaluate change, configuration, release, and patch management policies and practices.



120